Keycloak

R&D

SSO / Identité — Authentification Centralisée

En bref

Keycloak est une plateforme open-source de gestion des identités et des accès (IAM — Identity and Access Management). Il centralise l'authentification de toutes les applications de la stack (Odoo, Grafana, Flowise, Paperless...) via le protocole OIDC/OAuth2. Un seul mot de passe pour accéder à tout. Complexité technique élevée (Cx=4) — recommandé pour les clients avec 20+ utilisateurs ou des exigences de sécurité avancées.

Point clé

Keycloak est en phase **R&D** : fonctionnel et puissant, mais l'intégration avec les autres outils de la stack demande une expertise OIDC. Ne déployer que pour des clients avec un vrai besoin SSO multi-applications.

1 Ce que voit le client

Ce que voit et ressent le client

« Un seul mot de passe pour accéder à Odoo, à mon tableau de bord Grafana, à mon assistant IA et à mon coffre-fort. Quand un employé arrive, je crée un compte Keycloak et il accède à tout. Quand il part, je désactive le compte et il perd tous ses accès en 10 secondes. »

Gains mesurables :

- **Sécurité renforcée** : un seul point de contrôle pour tous les accès
- Fin de la gestion de 10–15 comptes différents par employé
- Onboarding simplifié : 1 compte créé = accès à toutes les applications autorisées
- Offboarding immédiat : désactivation = révocation de tous les accès en 10 secondes
- MFA centralisé : activer une fois dans Keycloak → s'applique partout

2 Installation technique

Prérequis : VPS-1 Core avec 2+ GB RAM dédié à Keycloak, Docker, Traefik. PostgreSQL recommandé comme base de données (pas H2 en production).

Listing 1 – docker-compose.yml — Keycloak + PostgreSQL

```yaml
version: "3.8"
services:
  keycloak-db:
    image: postgres:15-alpine
    restart: always
    environment:
      POSTGRES_DB: keycloak
      POSTGRES_USER: keycloak
      POSTGRES_PASSWORD: ${KC_DB_PASSWORD}
    volumes:
      - keycloak_db:/var/lib/postgresql/data

  keycloak:
    image: quay.io/keycloak/keycloak:latest
    restart: always
    command: start --optimized
```

```yaml
    depends_on:
      - keycloak-db
    environment:
      KC_DB: postgres
      KC_DB_URL: jdbc:postgresql://keycloak-db/keycloak
      KC_DB_USERNAME: keycloak
      KC_DB_PASSWORD: ${KC_DB_PASSWORD}
      KC_HOSTNAME: sso.votredomaine.com
      KC_HTTPS_PORT: 8443
      KC_PROXY: edge
      KEYCLOAK_ADMIN: admin
      KEYCLOAK_ADMIN_PASSWORD: ${KC_ADMIN_PASSWORD}
    labels:
      - "traefik.enable=true"
      - "traefik.http.routers.keycloak.rule=Host(`sso.votredomaine.com`)"
      - "traefik.http.routers.keycloak.tls.certresolver=letsencrypt"
      - "traefik.http.services.keycloak.loadbalancer.server.port=8080"

volumes:
  keycloak_db:
```

3 Configuration de base

Configuration du realm et des clients OIDC :

1. Accéder à `https://sso.votredomaine.com/admin` → créer le realm `client-nom`
2. Créer les clients OIDC pour chaque application :
   - **Grafana** : Client ID `grafana`, Redirect URI `https://grafana.votredomaine.com/login/generic_oauth`
   - **Odoo** : via le module `auth_oauth` → provider OpenID Connect
   - **Flowise** : Client ID `flowise`, via le module d'authentification
3. Configurer les groupes et rôles (Admin, User, Readonly)
4. Activer **MFA** (OTP) pour tous les utilisateurs du realm
5. Federation Active Directory/M365 : Identity Providers → Microsoft (via Azure AD)

Configuration Grafana SSO (grafana.ini) :

```ini
[auth.generic_oauth]
enabled = true
name = Keycloak SSO
client_id = grafana
client_secret = ${GRAFANA_OIDC_SECRET}
scopes = openid email profile roles
auth_url =
    https://sso.votredomaine.com/realms/client-nom/protocol/openid-connect/auth
token_url =
    https://sso.votredomaine.com/realms/client-nom/protocol/openid-connect/token
api_url =
    https://sso.votredomaine.com/realms/client-nom/protocol/openid-connect/userinfo
role_attribute_path = contains(roles[*], 'grafana-admin') && 'Admin' || 'Viewer'
```

4 Intégration dans la stack

Application	Protocole d'intégration
Grafana	Generic OAuth2 / OIDC (natif)
Odoo	Module `auth_oauth` (OpenID Connect)
Flowise	OIDC via proxy d'authentification
Azure AD	Fédération d'identité (les comptes M365 peuvent se connecter via Keycloak)

5 Rendre invisible côté client

— Les utilisateurs voient uniquement le bouton « Se connecter avec votre compte d'entreprise »
— La page de connexion Keycloak peut être customisée aux couleurs du client
— La synchronisation M365 Azure AD permet d'utiliser les mêmes identifiants
— En cas de problème Keycloak : chaque application conserve son propre fallback login

Maintenance mensuelle

- ☐ Vérifier que la connexion SSO fonctionne pour chaque application intégrée
- ☐ Contrôler les utilisateurs actifs et supprimer les comptes inactifs
- ☐ Vérifier la validité des tokens et la configuration des sessions (timeout)
- ☐ Sauvegarder la configuration Keycloak (export realm JSON)
- ☐ Mettre à jour l'image Keycloak (vérifier les breaking changes dans le changelog)